

GUÍA METODOLÓGICA: APLICACIÓN Y ANÁLISIS DE LA ENCUESTA INTEGRAL DE CIBERSEGURIDAD

Marco Detallado para Implementadores, Facilitadores y Analistas

Versión: 2.0 | **Fecha:** Enero 2026 | **Público:** Profesionales de Ciberseguridad, Consultores, CISOs, Analistas

PARTE I: PLANIFICACIÓN Y PREPARACIÓN

I.1 FASE PREVIA A LA ENCUESTA

I.1.1 Definición del Alcance

Objetivo: Determinar con precisión qué aspecto de la organización se evalúa.

Decisiones Clave:

Pregunta	Opciones	Implicación
¿Alcance geográfico?	Planta única / Múltiples regiones / Global	Define stakeholders, normativas aplicables
¿Cobertura de BU?	BU específica / Multi-BU / Corporativo	Afecta homogeneidad respuestas; comparatividad
¿Tipología de aplicaciones?	Críticas solamente / Todas las aplicaciones / Por categoría	Define escala de reflexión; número de respondentes
¿Función/rol objetivo?	Específico (ej: solo desarrolladores) / Multi-rol / Toda la organización	Influencia heterogeneidad datos; insights fricción
¿Primera evaluación o iteración?	Baseline / Re-evaluación (cuál fue anterior)	Define comparatividad; tracking de progreso

Salida: Documento de Scope de 1-2 páginas que describe en qué "segmento organizacional" se realiza la evaluación.

I.1.2 Selección de Stakeholders (Multi-rol)

Principio Clave: La encuesta está diseñada para **capturar perspectivas distintas de diferentes roles**. Esto es una fortaleza, no una debilidad.

Matriz de Roles Recomendada:

Rol	Excelencia en...	Por qué incluir	Cantidad mínima
Gobernanza	Governance, Compliance	Perspectiva estratégica; alignment negocio	1-2
Arquitecto	Design, Architecture decisions	Visión macro; trade-offs arquitectónicos	1-2
Desarrollador Senior	Implementation, Code quality	Realidad técnica del SDLC	2-3
QA/Testing	Verification, Testing, Security testing	Defect discovery perspective	1-2
Operations	Operations, Incident response	Producción; runtime security	1-2
Security/CISO	Governance, Verification	Perspectiva holística; policy enforcement	1 (facilitador preferible)
Compliance/Legal	Governance, Compliance, Regulatory	Perspective normativa	0-1 (si aplica)

Total mínimo: 8-13 respondentes para organización de ~100+ personas

Consideración: Menos de 5 respondentes puede resultar en sesgos significativos; más de 20 complica análisis sin agregar valor exponencial.

Actividad: Matriz de Asignación

Cree una matriz identificando:

- Nombre del respondiente
- Rol
- Equipo / Departamento
- Años en rol / Antigüedad
- Email para contacto

1.1.3 Comunicación Pre-Encuesta (2-3 semanas antes)

Objetivo: Establecer contexto, expectativas y urgencia.

Comunicación recomendada:

1. Email de Patrocinio (CISO/CIO)
2. "Por qué esto importa": alineación con NIS2, CRA, GDPR, objetivos de seguridad corporativo
3. "Quién está involucrado": roles específicos
4. "Cuándo": fecha/ventana de encuesta
5. "Cuánto tiempo": 45-60 minutos
6.
"Confidencialidad": "Respuestas individuales confidenciales; reportes agregados solamente"
7.
Sesión Informativa Inicial (20-30 minutos, opcional pero recomendada)
8. Explicar propósito de SAMM v2
9. Esclarecer escala 0-4 y que no hay "respuesta correcta"
10. Preguntar dudas
11.
Establecer deadline claro
12.
Recordatorio 1 semana antes
13. Link a encuesta (si digital)
14. Clarificar logística (QR, email, Google Form, etc.)

"Confidencialidad": "Respuestas individuales confidenciales; reportes agregados solamente"

Sesión Informativa Inicial (20-30 minutos, opcional pero recomendada)

Establecer deadline claro

Recordatorio 1 semana antes

1.1.4 Selección de Metodología de Administración

Opción A: Encuesta Digital (Recomendado para multi-respondentes)

- Ventajas: Consistencia, facilidad de análisis, timestamp, respuestas en propio ritmo
- Desventajas: Menos oportunidad de clarificación; requiere herramienta
- Herramientas: Google Forms, Typeform, SurveySparrow, Qualtrics, Jotform
- Tiempo: 45-60 minutos
- Costo: \$0-100 (herramienta básica vs. enterprise)

Opción B: Entrevista Facilitada (Recomendado como validación post-digital)

- Ventajas: Profundidad; facilita aclaración; captura observaciones cualitativas
- Desventajas: Tiempo intensivo; requiere facilitador experto; sesgos de facilitador
- Duración: 60-90 minutos por entrevista

- Mejor para: Roles clave (Gobernanza, Arquitectura, CISO); validación hallazgos
- Proceso: Encuesta digital primero; entrevistas post-análisis inicial para validar gaps/outliers

Opción C: Focus Group (Recomendado como complemento, no sustituto)

- Ventajas: Discusión; identifica fricción inter-roles; dinámicas grupales
- Desventajas: Muy time-intensive; social proof bias; no cuantificable
- Duración: 2-3 horas
- Mejor para: Post-análisis; discusión de discrepancias; roadmap collaborative
- Ejemplo: "Por qué Developers perciben Implementation en L2 pero Architecture percibe L1?"

Metodología Recomendada:

1. **Fase 1 (Semana 1-2):** Encuesta digital a todos
2. **Fase 2 (Semana 3):** Entrevistas facilitadas con 3-4 roles clave para validación
3. **Fase 3 (Semana 4):** Focus group (opcional) si existen discrepancias significativas

I.2 PREPARACIÓN DE LA ENCUESTA

I.2.1 Adaptación/Localización

Recomendación: La encuesta genérica es exhaustiva. Considere:

Escenario	Acción
Startup / PyME	Elimine preguntas sobre SIEM, Red Team, multi-entorno (preguntas I4.2.4, O6.1.5, S8.1.1+)
Operador Esencial (NIS2)	Enfatice Governance, Compliance, Incident Response; agregue preguntas de reporting a autoridades
Fintech / Sector Financiero	Agregue preguntas sobre PCI-DSS, DORA compliance; encriptación obligatoria
Salud / Farmacéutica	Agregue HIPAA, regulación sanitaria; data classification adicional
Sector Público (España)	Agregue ENS (Estándares de Seguridad de Administración Electrónica); normativas españolas
SaaS / Cloud-native	Enfatice container security, supply chain, API security

Salida: Versión "adaptada" de la encuesta con 60-90 preguntas (vs. 120+ generales).

I.2.2 Setup Técnico de Encuesta Digital

Si usa Google Forms / Typeform / Similar:

15. Crear estructura:
16. Página 1: Demográficos + Instrucciones
17. Páginas 2-10: 1 módulo por página (Gobernanza, Diseño, etc.)
18.
Página Final: Meta-preguntas (confianza, facilidad, observaciones)
19.
Validaciones:
20. Respuestas obligatorias para preguntas Likert
21. Permitir "No tengo suficiente visibilidad" como opción válida
22.
No forzar respuestas a preguntas N/A (ej: SIEM para PyME sin SIEM)
23.
Recolección de datos:
24. Habilitar timestamps
25. Permitir respuestas anónimas O registrar identidad (según política)
26.
Descargar respuestas a CSV para análisis post-recolección
27.
Testing:
28. Pruebe la encuesta usted mismo (completa en 60 minutos)
29. Comparta versión borrador con 1-2 facilitadores para feedback
30. Ajuste redacción, flujo, lógica condicional

Página Final: Meta-preguntas (confianza, facilidad, observaciones)

Validaciones:

No forzar respuestas a preguntas N/A (ej: SIEM para PyME sin SIEM)

Recolección de datos:

Descargar respuestas a CSV para análisis post-recolección

Testing:

PARTE II: ADMINISTRACIÓN Y RECOLECCIÓN DE DATOS

II.1 EJECUCIÓN DE LA ENCUESTA

II.1.1 Timeline Recomendada

Fecha	Actividad	Dueño
D-14	Email de patrocinio CISO	CISO
D-7	Sesión informativa; distribuir link	Facilitador
D-3	Recordatorio 1	Facilitador
D-0 a D+4	Ventana de encuesta abierta	Respondentes
D+1	Recordatorio 2 (mitad del período)	Facilitador
D+4	Cierre de encuesta; análisis comienza	Facilitador

II.1.2 Gestión de Respuesta / Follow-up

Tabla de Tracking:

Respondente	Rol	Enviado	Respondido	%	Recordatorio 1	Recordatorio 2	Status
Juan García	Dev	D-7	D+1	100%	N/A	N/A	✓ Completo
María López	QA	D-7	Pending	0%	D+1	D+2	🕒 En progreso

Meta: ≥ 80% de tasa de respuesta de respondentes identificados.

Contingencia: Si <60% de respuesta, considere extender ventana 3-5 días adicionales o contactar en persona.

II.1.3 Gestión de Problemas Técnicos

Problema	Solución
Respondente no puede acceder a link	Reenviar link; verificar permiso de dominio
Respondente está a mitad; pierde sesión	Herramienta debe soportar "guardar borrador"
Respondente quiere clarificación en pregunta	Facilitar NO debe enseñar respuestas; solo clarificar significado de términos

II.2 CALIDAD DE DATOS DURANTE RECOLECCIÓN

II.2.1 Banderas de Mala Calidad (En Tiempo Real)

Señal	Interpretación	Acción
Todos los Niveles 0 (completamente ad-hoc)	Posible: verdadero bajo nivel; o falta de visibilidad	Post-recolección: entrevista para validar
Todos los Niveles 4 (completamente optimizado)	Posible: verdadero alto nivel; más probablemente sesgo de deseabilidad	Solicitar ejemplos concretos en entrevista
Patrón: Respuestas 2, 2, 2, 2... (repetidas exactas)	Posible: "acertó la mitad del camino" sin reflexión	Dato válido pero de baja confianza
Tiempo completado: < 15 minutos	Posible: respuesta apresurada	Baja confianza; considere reentrevista
Tiempo completado: > 120 minutos	Posible: reflexión profunda o confusión	Revisar patrón de respuestas para validez

Acción: Revisar durante recolección; si <15 min o todas 0s, considere contactar para validar.

PARTE III: ANÁLISIS DE DATOS

III.1 PREPARACIÓN DE DATOS

III.1.1 Limpieza Inicial

Paso 1: Descargar respuestas de herramienta a CSV/Excel.

Paso 2: Crear matriz de datos con:

- Columnas: Cada pregunta (ej: M1.1.1, M1.1.2, G2.1.1, etc.)
- Filas: Cada respondente
- Valores: Respuestas (0-4, "N/A", texto si corresponde)

Paso 3: Validaciones básicas:

- Rango de valores (0-4, o N/A)
- No hay valores perdidos inesperados (diferente de "No sé" intencional)
- Timestamps razonables

Paso 4: Codificación:

- Si recopiló identidad, cree "ID respondente" anónimo (R01, R02, etc.)
- Mantenga mapping rol/ID en archivo separado, encriptado
- Proceda análisis en datos anonimizados

III.1.2 Agregación por Rol y Función

Crear matriz resumen:

	Rol	G (Gobernanza)	D (Diseño)	I (Implementación)	V (Verificación)	O (Operaciones)	SIEM	Training	
		-----	----	----	----	----	----	----	
	Developer 1	1.5	1.0	1.8	1.2	0.8	N/A	2.0	
	Developer 2	1.3	0.9	2.1	1.5	1.0	N/A	1.8	
	QA 1	1.8	1.5	1.5	2.5	1.2	N/A	2.2	
	Operaciones	1.2	0.8	1.2	1.0	2.8	1.5	1.5	

Cálculo de Puntuación por Función y Rol:

$$\text{Puntuación_Función_Rol} = (\sum \text{respuestas en función}) / (\# \text{ preguntas en función})$$

Ejemplo:

Gobernanza para Developers = $(1.5 + 1.3) / 2 = 1.4$

III.2 ANÁLISIS DESCRIPTIVO

III.2.1 Estadística por Función

Para cada función de SAMM (Gobernanza, Diseño, Implementación, Verificación, Operaciones):

Cálculos:

- **Media:** $\sum \text{puntuaciones} / n \text{ respondentes}$
- **Mediana:** Valor central (recomendado para escala ordinal)
- **Desviación Estándar:** Variabilidad de respuestas
- **Rango IQR (Q1-Q3):** Distribución central del 50% de datos

Tabla de Salida:

Función	Media	Mediana	Desv. Est.	Q1	Q3	Min	Max	n
-----	-----	-----	-----	----	----	----	----	----
Gobernanza	1.42	1.40	0.35	1.1	1.7	0.8	2.1	8
Diseño	1.18	1.15	0.52	0.8	1.5	0.2	1.9	8
Implementación	1.46	1.50	0.44	1.1	1.8	0.7	2.2	8
Verificación	1.35	1.30	0.58	0.9	1.7	0.5	2.3	8
Operaciones	1.81	1.85	0.42	1.5	2.1	0.9	2.5	8
Global SAMM	**1.44**	**1.42**	**0.41**	**1.1**	**1.7**	**0.7**	**2.1**	**8**

Interpretación:

- **Media:** Tendencia central; comparable a benchmark OWASP (~1.44)
- **Desv. Est.:** Si > 0.50 , existe **heterogeneidad importante** entre respondentes → oportunidad para focus group
- **Rango:** Si $\text{Max-Min} > 1.5$ puntos, existen **perspectivas conflictivas** en la organización

III.2.2 Análisis por Práctica de Seguridad

Para cada una de las 15 prácticas SAMM:

Práctica	Media	Mediana	Variancia	Outliers?	Observación
Strategy & Metrics	1.50	1.5	0.40	No	Moderadamente definida
Policy & Compliance	1.33	1.3	0.55	1 respondente en 0	Brechas de comunicación
Threat Assessment	1.00	1.0	0.60	Sí, rango 0-2	Muy inconsistente; necesita enfoque
Secure Build	1.60	1.6	0.35	No	Madurez relativamente buena

III.3 ANÁLISIS COMPARATIVO POR ROL

III.3.1 Heatmap de Discrepancias

Crear matriz: Filas = Roles; Columnas = Funciones SAMM

	Gobernanza	Diseño	Implementación	Verificación	Operaciones
Governance	1.9	1.2	1.3	1.1	1.5
Architects	1.4	1.8	1.5	1.6	1.3
Developers	1.2	0.8	1.8	1.0	0.7
QA/Testing	1.3	1.2	1.4	2.2	1.1
Operations	1.1	0.6	1.1	0.9	2.8

Identificar "desalineaciones":

Patrón	Significado	Acción
Gobernanza percibe "Governance" (1.9) vs. Developers (1.2)	Desalineación en percepción de estrategia	Necesita comunicación ejecutiva + sesión educativa
QA percibe "Verification" (2.2) vs. Developers (1.0)	QA "ve" testing sofisticado; Developers no lo perciben	Posible: QA no comunica rigor a devs
Todos perciben Operations bajo (0.7-1.1) excepto Operations (2.8)	Disonancia masiva	Riesgo crítico: Posible ilusión de Ops; o Ops hace trabajo no-reconocido

III.4 ANÁLISIS CUALITATIVO

III.4.1 Síntesis de Observaciones Abiertas

De la Pregunta Q11.2.1 (Comentarios Adicionales), extraiga **temas recurrentes**:

Ejemplo de síntesis:

Tema 1: "Amenaza del Talento"

- 3 respondentes mencionaron: "Tenemos mucha rotación de personas de seguridad"
- Implicación: Continuidad de iniciativas está en riesgo

Tema 2: "Fricción Desarrollo-Seguridad"

- 4 respondentes (principalmente Dev): "Requerimientos de seguridad ralentizan releases"
- Contrapunto: 2 personas de Verificación: "Developers omiten testing de seguridad"
- Implicación: Cultura de seguridad integrada aún en construcción; necesita liderazgo

Tema 3: "Herramientas de SIEM"

- 5 respondentes: "Nuestro SIEM genera demasiados falsos positivos; equipo sofocado"
- Implicación: MTTD artificialmente elevado; necesita tuning + ML

III.4.2 Análisis de Confianza y Facilidad

De las preguntas Q11.1.1 y Q11.1.2:

Confianza Media: 2.5/4 (Moderada)

- Gobernanza: 3.2 (Alta confianza en su dominio)
- Developers: 2.1 (Baja confianza en Governance/Operations)
- Implicación: Developers carecen de visibilidad en áreas fuera de su rol

Facilidad Media: 2.8/5 (Moderada)

- Preguntas con facilidad < 2: V7.1.4 (CVSS/EPSS scoring), S8.1.3 (SIEM eventos)
- Implicación: Preguntas sobre métricas técnicas especializadas son difíciles
- Acción: En entrevistas de validación, simplificar/aclarar esas preguntas

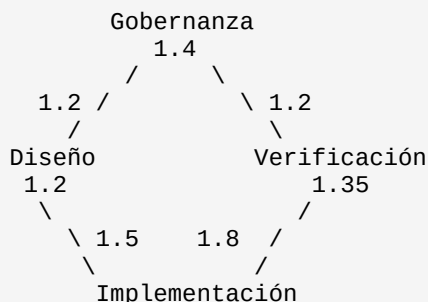
PARTE IV: SÍNTESIS E INTERPRETACIÓN

IV.1 CREACIÓN DEL PERFIL DE MADUREZ

IV.1.1 Diagrama Radial (Spider Chart)

Crear visualización con 5 ejes (Gobernanza, Diseño, Implementación, Verificación, Operaciones):

Ejemplo Texto (en gráfico real, use Plot.ly, Google Charts, etc.):



(Note: Operaciones 1.81 sería más alto fuera del patrón)

Interpretación del Radar:

- Superficie **convexa**: Maduro, equilibrado

- Superficie **cóncava**: Áreas de debilidad relativa
- **Punto de referencia**: Dibujar línea de "Target Maturity" (ej: 1.5 si NIS2/CRA compliance es objetivo)

IV.1.2 Perfil Narrativo

Describir la madurez organizacional en **lenguaje ejecutivo**:

Ejemplo:

Perfil de Madurez: Organización XYZ (Enero 2026)

XYZ presenta una madurez promedio SAMM de **1.44/3.0**, ubicándose en el **percentil 50 global** según benchmarks OWASP (n=30).

Fortalezas:

- Operations es la función más madura (1.81), reflejando inversión significativa en incident response y gestión de infraestructura.
- Implementation (1.46) muestra automatización emergente en CI/CD pipelines; gates de seguridad comenzando a implementarse.

Debilidades:

- Governance (1.42) y Diseño (1.18) son las funciones menores, indicando falta de estrategia documentada y amenaza modeling ad-hoc.
- Fricción importante entre roles: Developers perciben madurez en Implementation (1.8) pero arquitectos perciben solo 1.2 en Diseño.

Implicación de Cumplimiento:

- **NIS2 Readiness**: Requiere L1.8 mínimo. XYZ está en L1.44; **brechas moderadas** en Governance y Design.
- **CRA Readiness**: Requiere L1.55. XYZ está cerca pero con brechas en Design (threat modeling) y Verification (pentesting).

Recomendación Inmediata: Enfoque en **Governance** (estrategia, métricas) como "quick win" (3-6 meses) antes de design profundo.

IV.2 IDENTIFICACIÓN DE BRECHAS

IV.2.1 Matriz de Brecha

Para cada función:

Función	Actual	Target	Brecha	Severidad	Timeline
Gobernanza	1.4	2.0	-0.6	ALTA	6-9 meses
Diseño	1.2	1.8	-0.6	ALTA	6-12 meses
Implementación	1.5	2.2	-0.7	MEDIA	9-15 meses
Verificación	1.35	1.8	-0.45	MEDIA	6-9 meses
Operaciones	1.81	2.0	-0.19	BAJA	3-6 meses

Cálculo de Severidad:

- Brecha > 1.0 = **CRÍTICA** (cumplimiento regulatorio en riesgo)
- Brecha 0.6-1.0 = **ALTA** (debilidades significativas)
- Brecha 0.3-0.6 = **MEDIA** (mejoras recomendadas)
- Brecha < 0.3 = **BAJA** (optimizaciones menores)

IV.2.2 Análisis de Causa Raíz (Por Brecha Crítica)

Para cada brecha **ALTA o CRÍTICA**, investigar:

Técnica: "5 Whys"

Brecha: Diseño en 1.2 (target 1.8)

- ¿Por qué Design está bajo?
→ "Threat modeling es ad-hoc"
 - ¿Por qué threat modeling es ad-hoc?
→ "No existe metodología estándar; solo algunos arquitectos lo hacen"
 - ¿Por qué no existe metodología estándar?
→ "Recursos limitados; no se ha priorizado"
 - ¿Por qué no se ha priorizado?
→ "Gobernanza no lo ha comunicado como objetivo estratégico"
 - ¿Por qué Gobernanza no lo comunicó?
→ "CISO reciente; estrategia aún en construcción"
- ****Causa Raíz****: Falta de liderazgo estratégico + comunicación en Gobernanza

Salida: Para cada brecha, identificar 2-3 causas raíz; estos se convierten en **iniciativas de mejora**.

IV.3 BENCHMARKING EXTERNO

IV.3.1 Comparación con Benchmarks Disponibles

Fuentes:

Benchmark	Cobertura	Año	Nota
OWASP SAMM (oficial)	Global; 30 orgs	2024-2025	Promedio 1.44; sesgo grandes multinacionales
BSIMM	Global; 130 orgs	2024	Diferentes prácticas; no directamente comparable
Encuesta sectorial (si existe)	Por sector (ej: Financiero)	2024	Regional; específico sectorial
ENISA (NIS2 readiness)	Europa; por sectore	2025	Bajo normativa NIS2

Ejemplo Comparativo:

Métrica: Madurez Gobernanza

XYZ (Organización evaluada): 1.40
OWASP Global Median: 1.20
Benchmark Sector Financiero: 1.60 (si aplica)
NIS2 Target (operadores esenciales): 1.80

Interpretación:

XYZ está por encima de media global (+0.2), pero por debajo de pares sectoriales (-0.2).
Vs. requisito NIS2: Brechas significativas (-0.4).

PARTE V: ROADMAP DE MEJORA Y PRIORIZACIÓN

V.1 MATRIZ DE PRIORIZACIÓN

V.1.1 Factores de Priorización

Para cada iniciativa de mejora, evaluar:

Factor	Escala	Descripción
Impacto Regulatorio	1-10	¿Cierra brechas de cumplimiento NIS2/CRA/GDPR?
Riesgo de Negocio	1-10	¿Reduce probabilidad/impacto de incident?
Esfuerzo (Recursos)	1-10	¿Cuántos recursos requiere? (inverso: bajo esfuerzo = prioridad +)
Tiempo de Implementación	1-10	¿Cuánto tiempo hasta valor realizado? (rápido = prioridad +)
Dependencias	1-10	¿Otras iniciativas deben completarse primero? (pocas dependencias = prioridad +)

V.1.2 Matriz de Priorización

Crear matriz 2x2 (Impacto vs. Esfuerzo):

	ESFUERZO BAJO	ESFUERZO ALTO
IMPACTO ALTO	[QUICK WINS] - Comunicación Gobernanza - Training Básico - Template Threat Model	[PROYECTOS ESTRATÉGICOS] - Automatización SAST/DAST - Infraestructura SIEM - Rediseño Arquitectura
BAJO	[OPTIMIZACIONES] - Fine-tuning SIEM - Mejoras menores	[EVITAR] - "Big bang" initiatives - Proyectos sin ROI claro

V.1.3 Roadmap Temporal

TRIMESTRE 1 (3 meses): QUICK WINS

- [G2.1] Publicar estrategia AppSec documentada
- [T9.1] Lanzar programa training básico (30h/año mínimo)
- [D3.1] Publicar template de threat model (STRIDE)

Resultado esperado: Gobernanza → 1.6; Training → 2.3

TRIMESTRE 2-3 (6 meses): FUNDACIONALES

- [I4.1] Implementar SAST en build pipeline (80% cobertura)
- [V5.2] Establecer DAST estándar por release
- [O6.1] Formalizar incident response playbooks

Resultado esperado: Implementation → 1.8; Verification → 1.7; Operations → 2.0

TRIMESTRE 4-6 (9+ meses): AVANZADOS

- [D3.1] Threat modeling formal para críticas
- [S8.1] Implementación o mejora SIEM (si no existe)
- [I4.2] Secure deployment con verificación de firma

Resultado esperado: Global SAMM → 1.7-1.8; Cumplimiento CRA L1.55+

PARTE VI: REPORTE Y COMUNICACIÓN DE RESULTADOS

VI.1 ESTRUCTURA DEL REPORTE

VI.1.1 Executive Summary (1 página)

EXECUTIVE SUMMARY: Evaluación SAMM XYZ (Enero 2026)

MADUREZ ACTUAL: 1.44/3.0 (Percentil 50 global)

HALLAZGOS CLAVE:

✓ Operations madura (1.81): Incident response, infrastructure management establecidos
x Diseño débil (1.18): Threat modeling ad-hoc; sin arquitectura de referencia
⚠ Fricción inter-roles: Developers vs. QA perciben madurez de Verification 2x diferente

CUMPLIMIENTO REGULATORIO:

- NIS2 (Oct 2024 plazo): Actual 1.44 vs. Requerido 1.8 → Brecha -0.36 [MEDIA]
- CRA (Dic 2024): Actual 1.44 vs. Requerido 1.55 → Brecha -0.11 [BAJA]

RECOMENDACIÓN PRIORITARIA:

Enfoque en Gobernanza + Diseño (6-9 meses) para cerrar brecha NIS2; después escalar Verificación.

INVERSIÓN ESTIMADA: €150k-250k (recursos, herramientas, training) en 12 meses.

ROI: Reducción riesgo incidentes ~20-30%; cumplimiento regulatorio asegurado.

VI.1.2 Sección Técnica: Análisis Detallado (5-10 páginas)

Incluir:

- Tabla de puntuaciones por función + práctica
- Spider chart de madurez actual vs. target
- Análisis por rol (heatmap)
- Discrepancias principales identificadas
- Gráficos de distribución de respuestas (frecuencias)

VI.1.3 Roadmap de Mejora (3-5 páginas)

- Matriz de priorización (Quick Wins, Fundacionales, Avanzados)
- Timeline Gantt visual (Trimestres)
- Propietarios y budgets por iniciativa
- Métrica de éxito para cada trimestre

VI.1.4 Apéndice: Metodología

- Scope de evaluación (organizaciones incluidas)
- Respondentes (roles, n)
- Metodología (digital, entrevistas, focus groups realizados)
- Limitaciones (si aplica)

VI.2 COMUNICACIÓN A DIFERENTES AUDIENCIAS

VI.2.1 Board / Ejecutivos

Mensaje: Riesgo, cumplimiento, inversión requerida, ROI.

Formato: 1 página + 1 slide; 10 minutos presentación.

Talking Points:

- "Estamos en el percentil 50 global; competidores probablemente en percentil 65+."
- "Brechas identificadas crean riesgo regulatorio (NIS2, CRA) en 3-6 meses si no se actúa."
- "Inversión €150-250k en 12 meses reduce riesgo incidentes 20-30%; ROI justificado."

VI.2.2 CISO / Security Leadership

Mensaje: Detalles, brechas por función, iniciativas, interdependencias.

Formato: Reporte técnico completo (10-15 páginas); 60 minutos discusión.

Talking Points:

- "Fricción Developers-QA en Verification: necesita comunicación + training."
- "Operations es fortaleza; aprovechar como modelo para otras funciones."
- "Threat modeling es iniciativa L1 más importante; bloqueador para Design."

VI.2.3 Equipos Técnicos (Developers, QA, Ops)

Mensaje: Cómo USTEDES se perciben; oportunidades de mejora locales.

Formato: Taller interactivo; 60 minutos; resultados por equipo.

Talking Points:

- "Developers perciben madurez en Implementation pero no en Governance; vamos a comunicar mejor la estrategia."
- "QA: Vuestro rigor en testing es reconocido (2.2/3 en Verification); necesitamos escalarlo a todos los proyectos."

PARTE VII: VALIDACIÓN Y FOLLOW-UP

VII.1 ENTREVISTAS DE VALIDACIÓN (Post-Análisis)

VII.1.1 Selección de Respondentes para Entrevista

- 3-4 personas clave (1 por función crítica)
- Idealmente personas que también respondieron encuesta (para continuidad)
- Objetivo: Validar hallazgos, profundizar en causas raíz

VII.1.2 Guía de Entrevista (60 minutos)

Minuto 1-5: Contexto

"Aquí están los hallazgos de la encuesta. ¿Preguntas iniciales?"

Minuto 5-20: Validación de Puntuaciones

"La encuesta indica Design en 1.2. ¿Coincide con tu experiencia?"

"¿Por qué crees que Developers perciben Implementation en 1.8 vs. Arquitectos 1.2?"

Minuto 20-40: Profundidad en Brechas

"¿Cuáles serían los 3 cambios que más impactarían Design?"

"¿Qué recursos necesitarías para implementar threat modeling?"

Minuto 40-55: Roadmap Feedback

"¿Te parece realista la timeline? ¿Faltan iniciativas?"

Minuto 55-60: Cierre

"¿Hay algo que no se preguntó pero debería saberse?"

VII.1.3 Documento Post-Entrevista

Cada entrevista genera documento de 1-2 páginas:

- Puntos clave validados
- Nuevos insights
- Desacuerdos con encuesta (si aplica)
- Recomendaciones refinadas

VII.2 DISCUSIÓN COLECTIVA / FOCUS GROUP (Opcional)

Si existen **discrepancias significativas** entre roles:

VII.2.1 Setup

- Participantes: 6-8 personas (mezcla de roles)
- Duración: 2-3 horas
- Facilitador: Externo preferible (neutral)
- Método: World Café o similar

VII.2.2 Preguntas Provocativas

1. "¿Por qué Developers perciben Implementation en 1.8 pero Seguridad solo en 1.2?"
2. "¿Qué necesitaría pasar para que Gobernanza se sintiera 'real' en vuestro día a día?"
3. "¿Cuál es la mayor fricción entre equipos en seguridad de software?"
4. "Si tuviesen 6 meses y 1 millón de euros, ¿en qué enfocarían?"

Salida: Consenso sobre causas raíz; iniciativas alineadas.

PARTE VIII: REITERACIÓN Y MEDICIÓN DE PROGRESO

VIII.1 ESTABLECIMIENTO DE BASELINE Y MÉTRICA

Post-Primera Evaluación:

Métrica	Baseline (Enero 2026)	Target (Enero 2027)	Cadencia Medición
SAMM Global	1.44	1.65	Anual
Gobernanza	1.40	1.65	Anual
Diseño	1.18	1.50	Anual
Implementation	1.46	1.75	Trimestral (Automation)
Verification	1.35	1.60	Semestral (Testing)
Operations	1.81	1.95	Trimestral (Incidents)
SIEM Maturity	1.5	2.3	Semestral
Training Adoption	65%	85%	Trimestral

VIII.2 KPIs OPERACIONALES

Además de SAMM score, trackear:

KPI	Baseline	Target	Frecuencia	Owner
% Threat Models Actualizados	40%	100%	Trimestral	Architecture Lead
MTTD (Mean Time to Detect)	48h	4h	Mensual	SOC Manager
MTTR (Mean Time to Remediate)	7d (Crítico)	1d (Crítico)	Mensual	Incident Lead
Tasa de Fallo Phishing	15%	<5%	Mensual	Security Awareness
% Builds con Security Gates	60%	100%	Trimestral	DevOps Lead

VIII.3 RE-EVALUACIÓN ANUAL

Ciclo:

- **Enero Año 2:** Re-aplicar encuesta completa a mismos respondentes (si posible)
- Comparar Baseline vs. Year 1
- Análisis de progreso por función
- Ajustar roadmap para Year 2

Ejemplo Output:

PROGRESO SAMM: Enero 2026 → Enero 2027

Global: 1.44 → 1.65 (+0.21, +14.6%) ✓ On track (target: +0.21)

Gobernanza: 1.40 → 1.58 (+0.18) ✓

Diseño: 1.18 → 1.42 (+0.24) ✓✓ Excelente progreso

Operations: 1.81 → 1.88 (+0.07) ⚠️ Plateau; necesita nuevo impulso

APÉNDICE: HERRAMIENTAS Y PLANTILLAS

A.1 Plantilla de Análisis Excel

Disponible: [encuesta_analysis_template.xlsx] (macro-enabled)

- Hojas: Raw Data, Aggregation, Charts, Benchmarking
- Gráficos automáticos (Spider, Bar, Heatmap)
- Cálculos automáticos de media, mediana, SD

A.2 Template de Reporte PowerPoint

Disponible: [samm_report_template.pptx]

- Slide 1: Executive Summary (1 página)
- Slides 2-5: Technical Findings
- Slides 6-8: Roadmap
- Slides 9+: Apéndices (Data, Methodology)

A.3 Script Python para Análisis Automatizado

Disponible: [samm_analysis.py] (requiere pandas, numpy, matplotlib)

```
python samm_analysis.py --input responses.csv --output report/
```

CONCLUSIÓN

Esta guía proporciona un framework **riguroso pero flexible** para aplicar, analizar y actuar sobre la Encuesta Integral de Ciberseguridad.

Principio Clave: La encuesta no es **juicio de valor** sobre la organización, sino **brújula hacia madurez**. Las discrepancias entre roles no son "problemas" sino **oportunidades de alineación y mejora**.

Aplicada correctamente, esta metodología debería resultar en:

- ✓ Visibilidad clara de madurez actual vs. target
- ✓ Identificación de brechas críticas (regulatorio, operacional)
- ✓ Roadmap priorizado, realista y alineado con negocio
- ✓ Cultura de mejora continua en seguridad de software